

## Submission on the Discussion Document

### *Enhancing the cyber security of New Zealand’s critical infrastructure system*

**To:** National Security and Resilience Group, Department of the Prime Minister and Cabinet

**Email:** criticalinfrastructure@dpmc.govt.nz

**Date:** 18 April 2026

---

#### Submitter details

| Field                                                             | Value                                                                                                                                                                |
|-------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Submitter                                                         | Simon Nishi McCorkindale<br><a href="mailto:simon@spinsphere.xyz">simon@spinsphere.xyz</a>                                                                           |
| Organisation                                                      | ZRC Tapui Ltd (trading as Spinsphere for Kaysec post-quantum cryptography services)                                                                                  |
| Sector                                                            | Technology / Cyber Security / Quantum Technology / Quantum Computing                                                                                                 |
| Likely critical infrastructure entity under the draft thresholds? | No — Spinsphere is a small NZ-based research and services company. We provide post-quantum cryptography assessment and migration planning to other NZ organisations. |
| Website                                                           | <a href="https://spinsphere.xyz">spinsphere.xyz</a> / <a href="https://kaysec.spinsphere.xyz">kaysec.spinsphere.xyz</a>                                              |
| Consent to publication                                            | Yes, this submission may be published in full.                                                                                                                       |
| Commercially sensitive information withheld                       | None.                                                                                                                                                                |

---

---

#### Executive summary

Spinsphere (Kaysec) welcomes the Discussion Document and strongly supports the Government’s proposal to introduce a principles-based, minimum-requirements framework for the cyber security of New Zealand’s critical infrastructure system. On balance we support most of the six measures as drafted and believe the overall regime is proportionate, internationally aligned, and overdue.

However, the Discussion Document, Supplementary Document 1, and Supplementary Document 2 collectively contain **no substantive mention of cryptography, cryptographic agility, post-quantum cryptography (PQC), or NZISM Section 2.4**. We tested this directly — a full-text search of all three published consultation documents returns only incidental matches: NZISM referenced in passing in the context of defining a “serious impact” cyber incident (main document, p. 14), and the word “quantum” used in its non-technical sense (“penalty quantum”). This is a significant gap in a framework that will govern how New Zealand’s most essential services defend themselves for the next decade.

We set out below our evidence base — a first-of-its-kind public scan of 118 NZ critical infrastructure TLS endpoints published a few days before this submission — our account of how the post-quantum threat landscape has hardened over the last twelve months, and our specific recommendations for how the proposed framework can close the gap without expanding scope, cost, or regulatory burden.

Our three headline recommendations are:

1. **Measure 5 should explicitly require a cryptographic inventory as part of the risk management programme**, so that critical infrastructure entities cannot certify compliance without being able to tell the regulator which cryptographic primitives their essential services depend on.
2. **The framework should recognise “harvest now, decrypt later” (HNDL) as a material cyber risk** for any data subject to a long statutory or commercial confidentiality tail, and recognise that cryptographic agility is therefore in scope of the proposed risk management programme.
3. **The list of acceptable cyber security frameworks under Measure 5 should explicitly include NZISM** (which already addresses PQC in Section 2.4) alongside NIST CSF and ISO/IEC 27001:2022, and compliance with any listed framework should be required to include the framework’s cryptographic controls — not only its governance and process controls.

We expand on these below, along with responses to the specific questions posed in the Discussion Document.

## Evidence base — the 2026 NZ Critical Infrastructure PQC Readiness Scan

Kaysec has published an open-source tool (`nzism-pqc-audit`, MIT-licensed, hosted at [github.com/spinsphere/nzism-pqc-audit](https://github.com/spinsphere/nzism-pqc-audit)) that measures whether a public TLS endpoint will negotiate the NIST-standardised post-quantum hybrid key exchange X25519MLKEM768 (FIPS 203). On 14 April 2026 we ran this scanner against 118 New Zealand critical infrastructure entities, selected to approximate the draft thresholds in DPMC Supplementary Document 2.

The full methodology, target list, raw results and accompanying public report are published at <https://kaysec.spinsphere.xyz/nz-critical-infrastructure-post-quantum-security-readiness-assessment/>. Key findings:

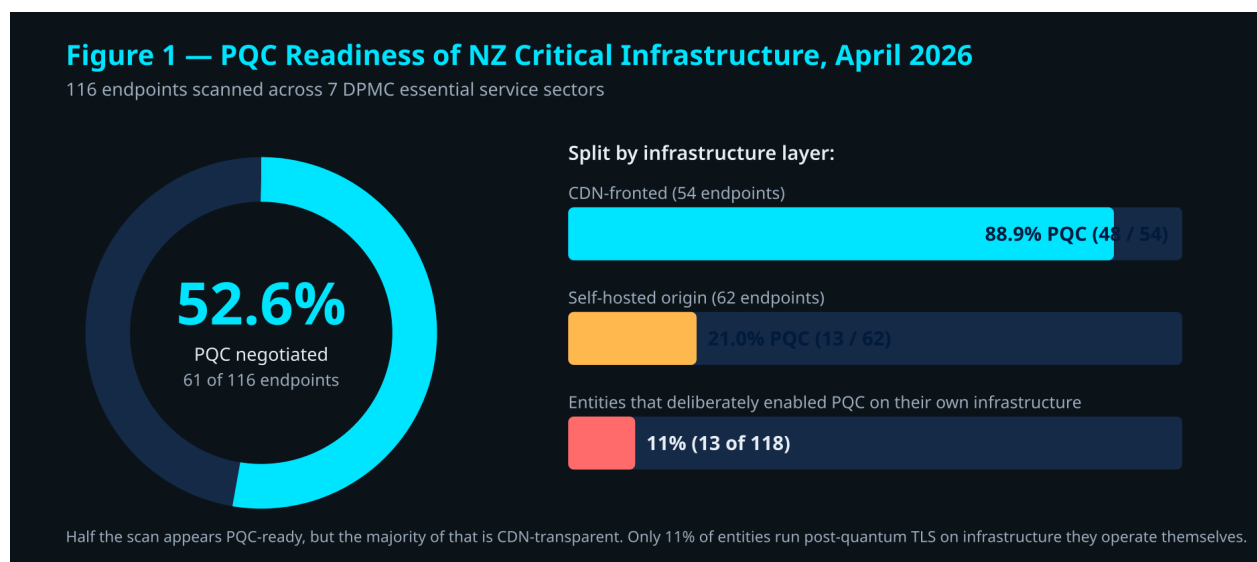


Figure 1: Figure 1 — Headline: 52.6% of NZ critical infrastructure endpoints negotiate post-quantum key exchange, but the majority is CDN-delivered

- **116 of 118 scans succeeded** (two transient handshake errors).

- **61 scans (52.6%) negotiated X25519MLKEM768.**
- **Of the 61 PQC-positive results, 48 were delivered by content delivery networks** — principally Cloudflare (28), Imperva (16), and AWS CloudFront (3). These providers enabled post-quantum TLS at the edge as part of vendor-led rollouts over 2024–2026. The New Zealand entities behind them received this protection transparently, without having had to take explicit action.
- **Only 13 entities (11% of the scanned population) had self-hosted origin infrastructure that negotiated PQC.** These are: GCSB, NZSIS, DIA, ANZ NZ, Meridian Energy, Firstgas, Manawa Energy, Pioneer Energy, Marlborough Lines, Tuatahi First Fibre, SBS Bank, The Co-operative Bank, and Vero Insurance. It is significant that three of these entities are New Zealand’s principal security and intelligence agencies, suggesting that the parts of Government with cryptographic expertise understand the need and have taken action.

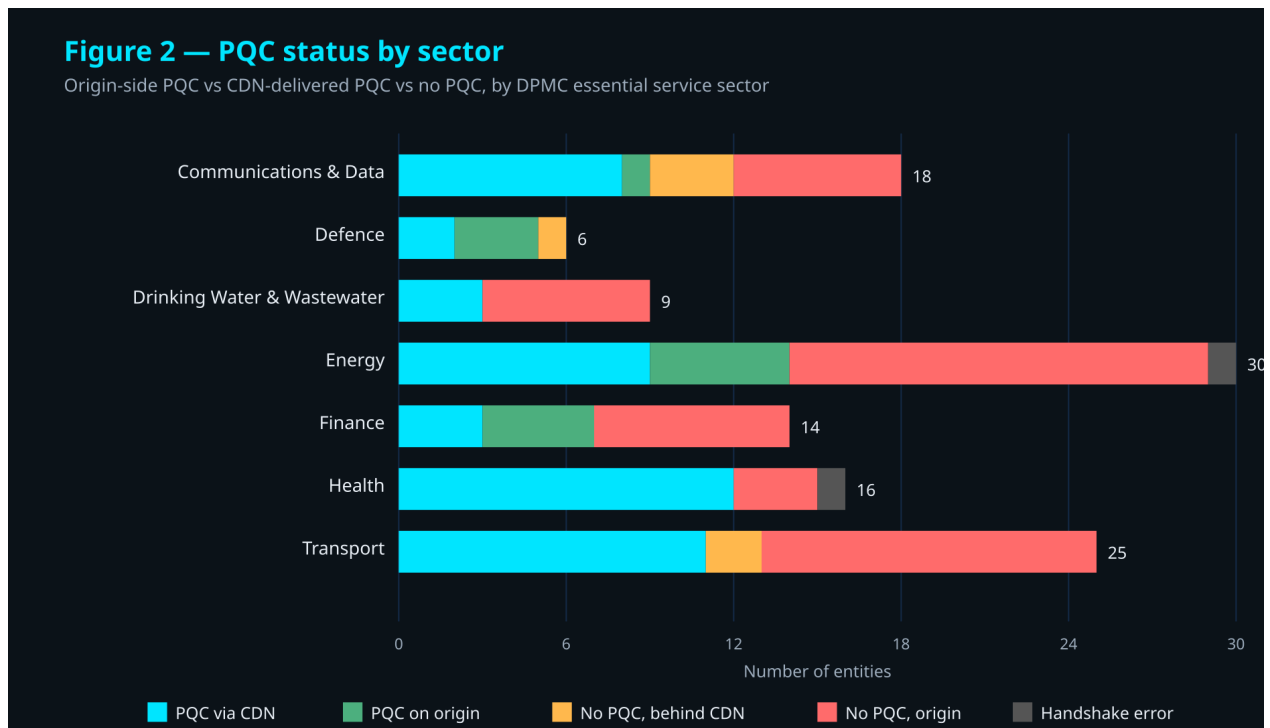


Figure 2: Figure 2 — PQC status by DPMC essential service sector

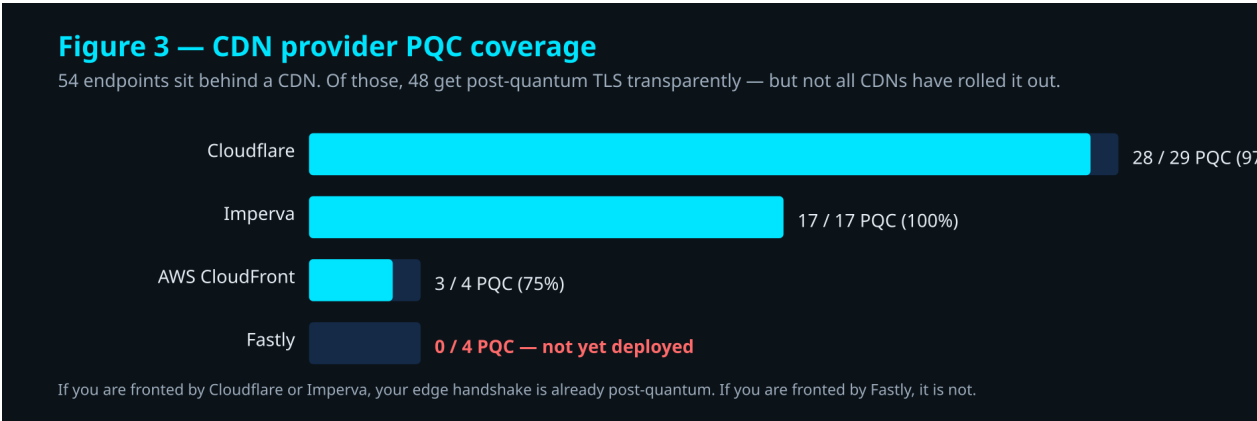
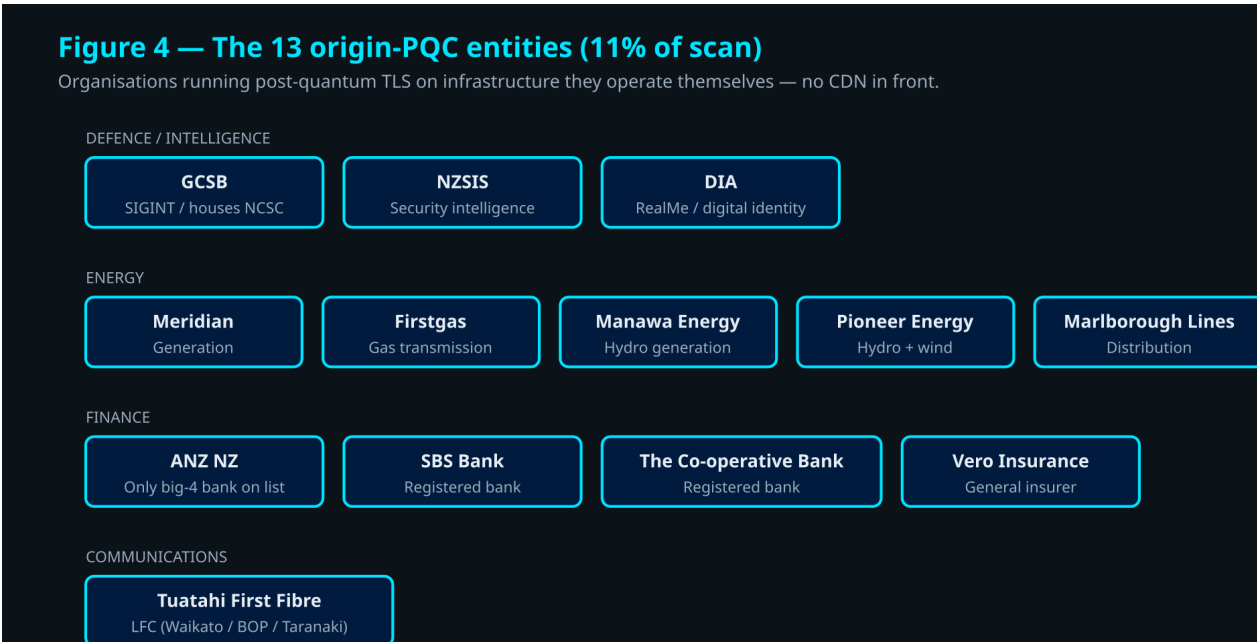


Figure 3: Figure 3 — CDN provider PQC coverage across NZ critical infrastructure



- **The Drinking Water & Wastewater sector had the lowest origin PQC rate — zero.** Six of nine scanned water utilities ran self-hosted infrastructure with no post-quantum key exchange enabled. This is consistent with the under-resourcing of the water sector on cyber security generally, which the Discussion Document itself implicitly acknowledges. - **Four entities are fronted by Fastly, which as of 14 April 2026 has not enabled PQC by default on its edge.** Those entities therefore have neither origin nor CDN post-quantum protection on their public web presence.

These findings would not change the substance of the proposed framework, but they demonstrate why cryptography must be within its scope. A regime that regulates cyber risk management for the services most essential to New Zealand’s economy and communities cannot remain silent about the primitives that make digital confidentiality, integrity and authentication possible in the first place.



Figure 4: Figure 5 — The DPMC critical infrastructure consultation contains no substantive mention of cryptography

## Why cryptography belongs in the framework

The Discussion Document identifies three outcomes the proposed measures are designed to deliver (p. 7):

1. an improved understanding of threats and vulnerabilities by critical infrastructure entities and government (Measures 1–4)
2. a minimum level of cyber risk management by all critical infrastructure entities (Measure 5)
3. effective management of cyber threats impacting national security (Measure 6)

Cryptographic posture is relevant to all three.

## The threat is hardening faster than most 2024-era assumptions

Three developments between May 2025 and April 2026 have pulled the quantum threat timeline forward to the point where the largest infrastructure providers in the world have publicly committed to accelerated migration:

**Gidney, May 2025.** A peer-reviewed arXiv pre-print [1] from Google Quantum AI showed that a 2048-bit RSA integer could be factored with fewer than one million noisy qubits — a 20× reduction, under identical hardware assumptions, from the same author’s 2019 estimate of 20 million qubits [2]. The reduction came purely from algorithmic improvements, not from any change to the assumed physical device characteristics.

**Google and Cloudflare, 25 March 2026.** Google’s VP of Security Engineering (Heather Adkins) and Senior Staff Cryptography Engineer (Sophie Schmieg) published a blog post setting **2029** as Google’s deadline for completing post-quantum cryptography migration across Google-operated systems [3]. Cloudflare pulled its own internal target forward to match, on the same day [4]. Both cited recent improvements in quantum resource estimates as the reason for accelerating. Boston Consulting Group’s accompanying position, widely reported alongside Google’s announcement, is that *“starting in 2030 will already be too late.”*

**Google Quantum AI, 30 March 2026.** A whitepaper from Google Quantum AI reported that elliptic curve cryptography — the primitive underlying the vast majority of current TLS key agreement, RealMe’s digital identity signatures, and New Zealand’s financial and government infrastructure — could be broken with fewer than 500,000 physical qubits in runtime measured in minutes, a ~20× reduction over the previous best (Litinski 2023, 9 million qubits) [5]. *The Quantum*

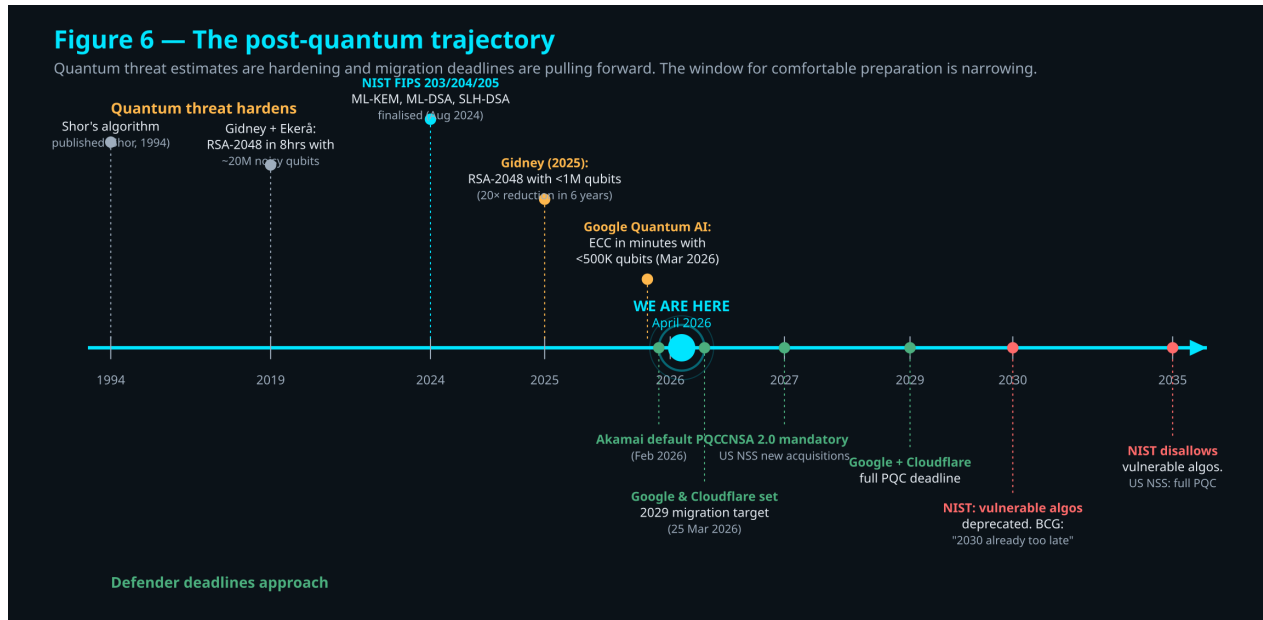


Figure 5: Figure 6 — The post-quantum threat trajectory: qubit estimates falling, migration deadlines accelerating

*Insider* characterised the period as “three papers in three months rewriting the quantum threat timeline” [6].

None of these results claim a cryptographically relevant quantum computer exists today. They do materially shorten the window between “does not exist” and “does exist,” and they sharpen the urgency of the harvest-now, decrypt-later (HNDL) threat model: any data encrypted today using RSA, ECDH or ECDSA, and captured today, is at risk of being decrypted during the working life of the proposed DPMC regime if its confidentiality requirement extends past roughly 2030.

## International alignment

New Zealand is, at the time of writing, alone among the Five Eyes in not having set a formal post-quantum migration deadline. For context:

- **United States (NSA, Commercial National Security Algorithm Suite 2.0).** New acquisitions of national security systems must be CNSA 2.0-compliant from 1 January 2027. Deployed software using CNSA 2.0 signatures by 2030. Full enforcement across US national security systems by 2031. Niche and legacy systems retired or replaced by 2033. Complete quantum resistance across all US NSS by 2035 [7].
- **United States (NIST IR 8547).** Quantum-vulnerable algorithms — RSA-2048 and ECDSA-P-256 explicitly in scope — deprecated after 2030 and disallowed after 2035 [8].
- **United Kingdom (NCSC-UK).** Published migration timelines in 2024 and 2025 with milestones through 2031 and 2035.
- **Australia (ASD / ACSC).** Published PQC transition guidance in 2024 and aligned with NIST deprecation schedules.
- **Canada (CCCS).** Published post-quantum guidance in 2024; Bill C-8 establishing a critical cyber system regime currently before Parliament.

The Discussion Document’s “International comparisons” section (p. 6) notes that New Zealand already lags on critical infrastructure cyber legislation generally. Cryptographic agility is the area of the comparison in which the gap is largest and most easily closed.

### **Compliance with the Discussion Document’s own framing**

The Discussion Document’s own definition of “material cyber risk” — a risk determined by a “reasonable person” test (p. 15) — already captures cryptographic risk. A reasonable person, advised that their organisation’s data will need to remain confidential for ten years but that an adversary may be able to decrypt it within that period, would treat this as material. Encryption that underpins essential services plainly qualifies. Requiring entities to maintain a cryptographic inventory as part of their risk management programme is the lowest-cost, highest-clarity way to make this concrete.

---

### **Responses to the specific consultation questions**

We respond to the questions that relate directly to our area of expertise. We take no position on questions outside it (for example, detailed regulator structure or compliance tool design).

#### **General questions**

##### **Q: Do you have any comment on the potential implications of each of the measures?**

We support the six measures as drafted, with one cross-cutting concern: none of them, as written, will oblige or incentivise an entity to understand its own cryptographic dependencies. Measure 5 is the natural home for this control.

##### **Q: Are you able to quantify the potential cost of compliance with each of the measures?**

For entities that already maintain some form of cryptographic control set under sector-based guidance (for example, NZISM-aligned government agencies, or RBNZ-supervised banks under the Deposit Takers Act 2023), the incremental cost of adding a cryptographic inventory requirement to Measure 5 is low — typically 20–60 person-days of specialist time for a medium-complexity organisation. For entities with no current cryptographic inventory — which is, to our knowledge, the overwhelming majority of the NZ mid-market and a meaningful proportion of CI entities — a first inventory will take 60–200 person-days depending on scope and heterogeneity. These estimates are broadly consistent with Australian experience under the Security of Critical Infrastructure Act 2018 risk management programme rules.

##### **Q: Do you think the right measures have been identified? If yes, which of the measures do you prefer and why?**

We prefer Measure 5 (minimum cyber risk management programme) as the central pillar, because it is the measure under which cryptographic inventory and PQC migration planning can be most naturally incorporated without adding new regulatory machinery. We also support Measure 4 (incident reporting) as an essential common-operating-picture control.

### **Section 1 — Defining critical infrastructure**

##### **Q: Would you support the proposed approach to defining critical infrastructure and critical infrastructure of national significance?**

Yes. We support the principles-based definition and the use of regulation-set thresholds. This approach is well aligned with the Australian SOCI Act 2018 model and allows thresholds to be refined without primary legislative change.

**Q: Do you consider any essential services have been included or excluded that should not be?**

One borderline case: *“Provision of cloud computing services”* (p. 10) is defined as being integral to the delivery of essential services by a specified number of critical infrastructure entities. We support its inclusion. We suggest the framework should also be explicit that the security posture of the underlying cryptographic primitives within cloud computing services is within scope for the cloud provider. Otherwise, large portions of the critical infrastructure system’s cryptographic exposure will sit behind commercial cloud contracts with no direct line of regulatory visibility. This is a particular concern given that the three hyperscale cloud providers each now operate or plan NZ-region infrastructure.

**Q: Do you think the example thresholds for defining critical infrastructure have been set appropriately?**

Broadly yes. Two practical observations from our target list research:

- **Energy generation 30 MW threshold.** Several generators between 25–30 MW appear materially important to regional supply. We note the Minister’s designation power (p. 9) as an appropriate safety valve.
- **Health threshold (“hospital with ICU”).** Practical and clear, but it does not distinguish between IT systems that are public-facing and those that are operational-technology-adjacent. The cryptographic posture of a patient administration system and the posture of a medical device network are very different questions; the framework should be designed so that both can be captured under the entity-level designation.

## Section 2 — Improving information sharing and collection

**Q: Do you agree with the proposed approach to protecting the data shared?**

Yes. The protections described on page 13 are appropriate. The limited-use obligation for incident reports (p. 14) is particularly important.

**Q: If the government required regular reporting of all cyber incidents, how frequently should this be required?**

Quarterly, with 24-hour / 72-hour triggers for significant incidents as proposed. Quarterly aligns with Australian practice and is the shortest cadence we believe small-to-medium critical infrastructure entities can sustainably meet without pushing cost up disproportionately.

**Q: Do you consider using the criteria of serious and above for cyber incidents that should be reported within 72 hours are appropriate?**

Yes. We note that the “serious impact” threshold references NZISM Section 7.2.14, which is appropriate.

**Additional recommendation for this section.** The incident reporting regime under Measure 4 should expressly include, within the definition of reportable incidents, any detected exploitation or failure of cryptographic primitives that the NCSC has formally advised should no longer be used.



This would create a feedback loop between cryptographic guidance (including NZISM Section 2.4) and the incident reporting system without any expansion of the framework.

### **Section 3 — Introducing minimum cyber risk management requirements**

**This is the section where our primary recommendations sit.** We address the specific questions in order.

**Q: Are any of the specific words proposed to set the requirements of the risk management programme on page 15 likely to conflict with your existing approach to risk management?**

No, but we note an absence. The risk management programme as described identifies “components that are critical to the delivery of essential services” (p. 15, first bullet). It does not identify cryptographic components specifically. We recommend adding a sub-bullet along the lines of: *“maintains an inventory of the cryptographic primitives, libraries, key management systems and certificate chains that underpin the critical components identified above.”* This sits naturally within the existing text without requiring a structural rewrite.

**Q: Do you agree that critical components should be defined in a way that aligns with the scope of the requirements in the emergency management system?**

Yes.

**Q: Do you consider that the concept of a risk that is “material” can be given effect to within your existing approach to enterprise risk management?**

Yes, but we note that harvest-now-decrypt-later (HN DL) cryptographic risk is not currently captured in standard enterprise risk management frameworks, because the time horizon — a decade or more — is longer than typical ERM windows. The framework should be clear that a risk does not become immaterial simply because its realisation is more than five years away. We recommend that guidance issued alongside the regime explicitly list HN DL as an example of a material cyber risk for entities handling data with long confidentiality tails. The Gidney 2025 and Google Quantum AI 2026 results described above are directly relevant to this point — the horizon between “threat is theoretical” and “threat is operational” has shortened materially in the last twelve months.

**Q: Do you consider that the threshold for treating risks should be set at “so far as reasonably practicable”?**

Yes. This threshold is well understood in NZ law (notably under the Health and Safety at Work Act 2015) and will be workable here. We observe that “reasonably practicable” should be read as including the cost-benefit of cryptographic agility investments relative to the expected data retention tail.

**Q: Do you support the risk management programme complying with a cyber security framework that is endorsed by the NCSC or recognised internationally?**

Yes. We strongly recommend that the framework explicitly list **NZISM** among the acceptable cyber security frameworks for Measure 5 compliance, alongside NIST CSF and ISO/IEC 27001:2022. NZISM is the natural NZ-specific reference, is maintained by the NCSC, and uniquely among the listed frameworks already contains a post-quantum cryptography section (Section 2.4). Not listing it would create the perverse outcome that a NZ-specific critical infrastructure framework implicitly favours imported frameworks over the domestic one.

We also recommend that the framework require an entity claiming compliance with any listed framework to demonstrate that they have applied that framework’s cryptographic controls — not only its governance, risk and process controls. This is a common failure mode under NIST CSF adoption in particular: entities implement the Identify/Protect/Detect/Respond/Recover scaffolding without applying the technical controls to which those functions refer.

**Q: Do you agree that government should not prescribe the internationally recognised cyber security frameworks that are acceptable?**

On balance, no — we think a short, named list provides more certainty, reduces compliance cost, and supports the “proportionate” principle. We would suggest NZISM, NIST CSF, ISO/IEC 27001:2022, and the CIS Critical Security Controls as a workable initial list. A named list also avoids the edge case in which an entity selects a vendor-published “framework” that is not genuinely equivalent to the others.

**Q: Do you consider that a requirement for third-party vendors that have operational control over critical components, to support responsible entities to comply to the extent reasonably practicable, is important?**

Yes — and we note that this is especially important for cryptographic components. Many critical infrastructure entities outsource their TLS termination to a CDN, their email encryption to a cloud mail provider, or their signing infrastructure to a commercial HSM service. The “reasonably practicable” support obligation should extend to these vendors providing information about the cryptographic primitives their services use on the entity’s behalf. Without this, an NZ critical infrastructure entity cannot maintain an accurate cryptographic inventory even if it wants to. Our scan result — 48 of 61 PQC-positive endpoints being CDN-delivered rather than origin-delivered — is direct evidence of this dependency.

**Q: Do you consider that there are alternative ways for the government to recognise that compliance with other regulation is equivalent to the minimum requirements?**

Yes — we support the existing proposal for the critical infrastructure regulator(s) to issue a determination that a set of sector-based regulations meets the minimum. We recommend such determinations expressly address whether the sector-based regime covers cryptographic agility, because most sector regimes today do not.

### **Section 3 — Ensuring effective management of cyber threats impacting national security**

We take no position on the detailed design of Measure 6 other than to support it in principle.

### **Section 3 — Ensuring mandatory requirements improve cyber security**

We take no position on the specific compliance and enforcement design, other than to note that director individual liability (p. 24) is appropriate for serious and critical breaches and consistent with international practice.

---

## **Our three recommendations, restated**

**Recommendation 1 — cryptographic inventory.** Measure 5 should require, as part of the mandatory risk management programme, that each critical infrastructure entity maintain an

inventory of the cryptographic primitives, libraries, key management systems and certificate chains that underpin its identified critical components. This adds approximately 20 words to the current drafting on page 15 and creates no new regulatory machinery.

**Recommendation 2 — HN DL as material cyber risk.** The framework’s guidance should explicitly identify harvest-now-decrypt-later cryptographic risk as a material cyber risk under Measure 5 for any entity handling data with long statutory or commercial confidentiality tails (health, legal, financial retention, state-related information, long-lived industrial IP). This does not change the legal definition of “material” — it provides operational clarity that supports consistent interpretation.

**Recommendation 3 — NZISM in the framework list.** The list of acceptable cyber security frameworks under Measure 5 should include NZISM alongside NIST CSF and ISO/IEC 27001:2022. Compliance with any listed framework should include application of its cryptographic controls, not only its process controls.

---

## Additional observations

**On the “phased approach to compliance” (p. 19).** The one-year grace period is appropriate. We suggest that during this grace period the Government uses the opportunity to publish — through the NCSC and in collaboration with DPMC — a formal cryptographic inventory template, aligned with NZISM Section 2.4, that critical infrastructure entities can adopt without having to design their own. This would materially reduce compliance cost for the long tail of smaller entities and would directly address the capability gap identified on page 16.

**On the “international comparisons” section (p. 6).** Each of the four comparator regimes discussed (Australian SOCI, EU NIS2, UK CSR Bill, Singapore Cybersecurity Act) either already references cryptographic agility or has had explicit post-quantum guidance layered on top. New Zealand is in an unusual position where it could leapfrog straight to a framework that treats cryptographic agility as a baseline control, given the relative novelty of its critical infrastructure regime. This is an opportunity.

**On the omission.** We do not think the omission of cryptography from the Discussion Document is a deliberate exclusion. We think it reflects the fact that the document is primarily concerned with governance, incident response, information sharing and risk management processes — all of which are important — and that the cryptographic layer has simply not been brought into that scope. This submission argues that it should be. We would be happy to discuss any of the points above in more detail, and to share the scan data, methodology, and target list with DPMC or the NCSC if that would be useful.

---

## References

- [1] Gidney, C. (2025). “How to factor 2048 bit RSA integers with less than a million noisy qubits.” arXiv:2505.15917. <https://arxiv.org/abs/2505.15917>
- [2] Gidney, C. and Ekerå, M. (2019). “How to factor 2048 bit RSA integers in 8 hours using 20 million noisy qubits.” arXiv:1905.09749. <https://arxiv.org/abs/1905.09749>

- [3] Adkins, H. and Schmieg, S. (2026, March 25). “Google’s timeline for post-quantum cryptography migration.” Google Blog. <https://blog.google/innovation-and-ai/technology/safety-security/cryptography-migration-timeline/>
- [4] Cloudflare. (2026, March 25). “Cloudflare targets 2029 for full post-quantum security.” <https://blog.cloudflare.com/post-quantum-roadmap/>
- [5] Google Research. (2026, March). “Safeguarding cryptocurrency by disclosing quantum vulnerabilities responsibly.” <https://research.google/blog/safeguarding-cryptocurrency-by-disclosing-quantum-vulnerabilities-responsibly/>
- [6] The Quantum Insider. (2026, March 31). “Q-Day just got closer: three papers in three months are rewriting the quantum threat timeline.” <https://thequantuminsider.com/2026/03/31/q-day-just-got-closer-three-papers-in-three-months-are-rewriting-the-quantum-threat-timeline/>
- [7] NSA. (2025, May). “Commercial National Security Algorithm Suite 2.0.” [https://media.defense.gov/2025/May/30/2003728741/-1/-1/0/CSA\\_CNSA\\_2.0\\_ALGORITHMS.PDF](https://media.defense.gov/2025/May/30/2003728741/-1/-1/0/CSA_CNSA_2.0_ALGORITHMS.PDF)
- [8] NIST. (2024). “NIST IR 8547 (Draft): Transition to Post-Quantum Cryptography Standards.” <https://csrc.nist.gov/pubs/ir/8547/ipd>
- 

## Contact and sign-off

Spinsphere Founder: Simon Nishi McCorkindale

Email: [simon@spinsphere.xyz](mailto:simon@spinsphere.xyz)

Web: [spinsphere.xyz](https://spinsphere.xyz) · [kaysec.spinsphere.xyz](https://kaysec.spinsphere.xyz)

Supporting evidence: [github.com/spinsphere/nzism-pqc-audit](https://github.com/spinsphere/nzism-pqc-audit)

Accompanying public report: <https://kaysec.spinsphere.xyz/nz-critical-infrastructure-post-quantum-security-readiness-assessment/> (*New Zealand Critical Infrastructure: The First Public Post-Quantum Readiness Assessment*, 15 April 2026)

Submitted 18 April 2026. We consent to this submission being published in full under the Official Information Act 1982.